Crypto Investigator

Technical Validation Document

Software version	v0.4.0 (file: VERSION)
Document generated	2026-07-09 17:29 UTC
Generated by	tools/make_docs.py (part of the audited source)
Complete source listing	docs/listings/v0.4.0-full-listing.txt
Listing SHA-256	327ed3b5fc7a95b27da384ac6860075070be915ff9d68a0264f19f4af6ae3f42
Audience	Independent technical experts, prosecutors, and courts evaluating the reliability of this tool's output

1. Purpose and scope

This tool follows cryptocurrency from a victim's wallet across public blockchains until the funds reach a custodial service (an exchange or similar business) on which legal process can be served. Its deliverable is a set of exit points - addresses, transaction IDs, timestamps and amounts - packaged with draft records-request language and a complete chain-of-custody log.

What the tool does not do. It does not identify natural persons; account-holder identity must come from the custodian's KYC records via subpoena or warrant. It does not 'demix' mixing services, guess at continuity across privacy tools, or produce risk scores. It uses only public data, and it never presents an inference as a fact: every attribution and heuristic carries a stated confidence level and basis.

2. Design principles

- **Facts are separated from inferences.** On-chain transactions (IDs, amounts, timestamps) are reported as facts. Roles, attributions and classifications are inferences, each carrying a confidence level (HIGH / MEDIUM / LOW) and a written basis stating its source.
- **Dead ends are reported honestly.** Mixers, smart contracts, privacy coins and unlabelled busy services stop the trace and are flagged as such. The tool never fabricates continuity through an obstacle.
- **Every data acquisition is reproducible.** Each network pull is recorded with its exact request URL, UTC timestamp, HTTP status, and the SHA-256 hash of the raw response body, so any analyst can re-issue the request and compare hashes.
- **Public data only.** All sources are publicly accessible; no proprietary attribution database is used or simulated.
- **Local and offline-safe.** The application binds to 127.0.0.1 only; case data never leaves the machine.

3. System architecture

The software is a single-machine Python application (FastAPI web server, SQLite storage, browser-based user interface). No component is exposed to the network; the server listens on 127.0.0.1:8321 (localhost) only.

Modules, each inlined in full in the source listing:

- **app/config.py** - every tunable constant (thresholds, caps, endpoints) in one auditable file; no logic.
- **app/database.py** - SQLite schema and access: cases, traces, settings, labels, the immutable HTTP evidence cache, the chain-of-custody log, and IC3 worksheet drafts.

- **app/providers/** - data acquisition clients (Bitcoin via the Esplora API, Ethereum via Etherscan V2) built on a shared base class that enforces cache, throttle, retry and custody logging for every request.
- **app/labels/** - attribution store: OFAC SDN parsing and the bundled community exchange list.
- **app/tracing/** - input format detection and the forward tracing engine.
- **app/prices.py** - USD context values from CoinGecko (spot ticker and historical daily prices).
- **app/report/** - the court-ready trace report and the IC3 complaint worksheet (PDF generation).
- **app/ic3.py** - IC3 complaint worksheet data model and trace prefill.
- **app/static/** - the browser interface (plain HTML/JS/CSS; the only third-party component is the bundled Cytoscape.js graph library, served locally).

4. Data sources

- **Bitcoin:** Esplora-compatible REST API, default https://mempool.space/api (mempool.space); https://blockstream.info/api (Blockstream) is a drop-in alternative. No API key. The endpoint is user-swappable in Settings, and every response is hash-logged, so the specific host used for any given pull is a matter of record.
- **Ethereum and ERC-20 tokens:** Etherscan V2 API (https://api.etherscan.io/v2/api), free user-supplied key. The key is excluded from logged URLs and cache keys, so custody logs are shareable and re-runnable by another analyst using their own key.
- **Sanctions attribution:** the official US Treasury OFAC SDN list, downloaded live from https://www.treasury.gov/ofac/downloads/sdn.xml and parsed for digital-currency addresses. Imported at HIGH confidence (official government source). Never cached - each refresh records which snapshot (by hash) was used.
- **Exchange attribution:** a small bundled list of publicly documented exchange wallets (data/labels/exchange_labels_seed.json), derived from public block-explorer entity tags. Imported at MEDIUM confidence and marked unverified. The tool states in every report that absence of an exchange label is not evidence of absence.
- **USD prices (context only):** CoinGecko public API (https://api.coingecko.com/api/v3). Not evidence; see section 8.

5. Acquisition integrity (chain of custody)

All network access flows through one code path (app/providers/base.py) that applies, in order:

- **Evidence cache.** Confirmed on-chain data is immutable, so the first captured response for a given request is stored permanently in SQLite (raw bytes + SHA-256) and served from disk thereafter; existing entries are never overwritten. Data that can change (address activity, sanctions list, prices for the current day) is deliberately never cached.
- **Throttling.** A per-source minimum request interval keeps the tool inside free-tier limits (e.g. 0.6s for mempool.space, 3.0s for CoinGecko).
- **Retry.** Rate-limit and server errors back off exponentially up to 4 attempts; a 404 is treated as a definitive answer and logged, not retried.
- **Custody logging.** Every acquisition - live or from cache - is appended to the custody_log table with: source, the exact re-runnable request URL, HTTP status, SHA-256 of the raw body, whether it was served from the evidence cache, and a UTC timestamp. The full log exports as CSV and appears (up to a size cap) as an appendix in every trace report.

6. Tracing algorithm

6.1 Starting point. A trace is anchored to the victim's wallet address, confirmed by the investigator. Optionally, one 'focus transaction' hash restricts direction: only that payment's outputs leaving the victim wallet become the first hop (outputs returning to the victim wallet - change - are excluded). The engine verifies the wallet actually participates in the focus transaction: if the wallet is only a recipient, the trace falls back to the full wallet with a written warning; if the wallet is not in the transaction at all, the trace fails with an explicit error rather than tracing the wrong funds. For a multi-input Bitcoin transaction, outputs are attributed to the payment as a whole and the report says so. In a focus-transaction trace, hops are counted from the FIRST SUSPECT WALLET (the payment's recipient); the focus payment itself is the approach to hop 1.

6.1a Time-forward rule. Money cannot flow backward in time: every address in the trace is examined only from the moment the traced funds arrived at it, and movements dated earlier are ignored (their count appears in a written warning). A suspect wallet's unrelated prior history therefore cannot enter the trace.

6.2 Expansion. The engine walks breadth-first from the starting point, following outgoing movements hop by hop up to a user-set depth (1-6 hops; default 3). When a focus transaction sets the direction, the investigator may instead select EXTENDED mode: the payment is followed until it reaches a labelled exchange, bounded by 25 hops and the size caps in 6.5. Extended mode stops the moment an exchange is identified and reports any unexplored branches as such. Movements below the dust thresholds (defaults 0.0001 BTC / 0.001 ETH / 1.0 token units, user-adjustable) are not followed. Value accounting is taint-by-touch ('poison'): every qualifying outgoing movement is followed in full; per-unit apportionment (FIFO/haircut) is not applied, and every report states this.

6.3 Movement semantics. Bitcoin: for each transaction where the traced address appears in an input, each output is a movement; outputs paying the traced address itself are treated as change and excluded; non-standard outputs (e.g. OP_RETURN) have no destination address and are skipped. Ethereum: native ETH transfers plus ERC-20 token transfers sent from the traced address, newest first; reverted transactions and zero-value contract calls are skipped; token amounts use the token's reported decimals, with USDT/USDC handled by vetted constants.

6.4 Classification. Before an address is expanded it is classified, in this priority order, and stopping roles are not expanded further: (1) OFAC-sanctioned (official list, HIGH confidence); (2) labelled mixing service - flagged 'trail obscured', never guessed through; (3) labelled exchange - recorded as an EXIT POINT, the deliverable; (4) smart contract (Ethereum) - flagged, not followed; (5) high-activity heuristic - an address with more than 500 transactions is treated as a probable service and not expanded (explicitly labelled a LOW-confidence heuristic); otherwise (6) intermediary pass-through. Exit detection also runs the moment an edge lands on a labelled exchange, so exits at the depth limit are still captured.

6.5 Safety caps (all reported when hit). Per address, only the most recent 25 outgoing transactions are followed; a trace is capped at 400 addresses and 1500 movements. When any cap or the depth limit stops exploration, the affected addresses are marked 'unexpanded / trail edge' in the map, the report and the warnings - the tool records where it stopped looking.

7. Attribution and confidence model

Attribution labels live in one table with their source and confidence, and reports print both. The tiers are:

- **HIGH** - official source (US Treasury OFAC SDN list) or multiple corroborating sources.
- **MEDIUM** - a single reputable public/community source (e.g. a block-explorer entity tag); unverified.
- **LOW** - a heuristic inference produced by this tool's own analysis (e.g. the high-activity flag).

A role assigned during tracing (victim, intermediary, exchange, sanctioned, mixer, contract, high-activity, unexpanded) is an analytical inference; each node's written basis states exactly why it was assigned, and the report's address table reproduces these bases verbatim.

8. USD valuation (context, not evidence)

Movements in BTC and ETH are annotated with an approximate USD value computed from CoinGecko's daily price for the transaction's UTC date; USDT and USDC are valued at $1.00 by the peg; all other tokens are left unvalued rather than guessed. Intraday movement is not captured. Every surface that shows a USD figure labels it an estimate, and the report's methodology section repeats the limitation. Price requests go through the same custody-logged pipeline as blockchain data; past dates are immutable and cached, the current day is not. A price-source outage degrades the trace to crypto-only amounts with a warning - it can never change or fail a trace. The live ticker in the interface is display-only and stored nowhere.

9. Outputs

- **Trace report (PDF)** - case summary; ranked exit points with funding transactions; DRAFT records-request language per custodian (marked for counsel review); address table with role bases; complete transaction table; methodology and limitations; chain-of-custody appendix.
- **Chain-of-custody log (CSV)** - every acquisition for the trace, complete and machine-readable.
- **Raw trace result (JSON)** - the full graph, exits and warnings for interoperability and archival.
- **Fund-flow traceroute** - for every exit, a hop-by-hop path from the victim wallet to the exchange deposit address (addresses, amounts, USD estimates, transaction IDs, UTC times), printed in the report and exportable as plain text for quotation in a search warrant or affidavit.
- **IC3 complaint worksheet (PDF)** - mirrors the section order and field labels of the official FBI complaint form at complaint.ic3.gov, prefilled from trace data where possible. IC3 offers no electronic submission; the worksheet is transcribed by a person, and the tool says so.

10. Visualization integrity

The money-flow map offers readability aids: runs of one-in/one-out pass-through addresses collapse into a single dashed edge, multiple deposit addresses of one exchange group into an entity node, and sprays of small dead-end branches fold into a counted stub. These are display operations only. The underlying result - every address, movement, amount and hash - is unaffected: collapsed elements list their full contents when clicked, an 'Expand all' control shows every address individually, and the PDF, CSV and JSON exports always contain the complete data regardless of the display state.

11. Known limitations

Each release ships a changelog (CHANGELOG.md) whose 'known limitations' sections are part of this validation record. Material limitations as of this version:

- Only the most recent 25 outgoing transactions per address are examined; heavy later activity can conceal an older spend (a date-window filter is roadmapped).
- No Bitcoin wallet clustering or change-address detection beyond same-address change: a suspect's own change to a fresh address is followed like any other movement.
- Funds entering smart contracts (swaps, bridges, mixers) are flagged and not traversed; no continuity is invented.
- The bundled exchange label list is small; absence of an exit finding is not evidence of absence.
- USD figures are daily-price approximations (section 8).

• API keys are stored unencrypted in the local database; disk encryption on the evidence machine is recommended.

• Tron, Monero and Litecoin inputs are recognised and explained but not traceable in this version (Monero is not traceable on-chain by design).

12. Verification procedures for reviewers

12.1 Identify the software. The version is in the VERSION file and on every report. The complete source of this version is inlined in a single file, docs/listings/v0.4.0-full-listing.txt, whose SHA-256 appears on page 1 of this document. Comparing that hash validates that the code under review is the code that produced the output.

12.2 Reproduce any data pull. Take any row of a trace's custody log, re-issue the recorded URL (for Etherscan rows, append your own free API key), hash the response body with SHA-256 and compare. Confirmed historical records (a transaction by ID) are immutable and must match exactly; address-level endpoints append new activity over time, which is why the log records the acquisition timestamp.

12.3 Reproduce a trace. Given the report's victim wallet, focus transaction (if any), depth and dust parameters - all printed in the case summary - an independent installation of the same version will fetch the same underlying records and reach the same exit points, subject to label-list currency (the OFAC snapshot used is hash-logged).

12.4 Inspect the evidence store. All data lives in data/investigator.db, a standard SQLite database openable with any SQLite tool. The http_cache table holds the raw response bytes exactly as received, alongside their hashes.

12.5 Examine the code. The application is small by design (~a few thousand lines, no build step, dependencies pinned in requirements.txt: fastapi, uvicorn, httpx, reportlab). Every constant that affects tracing behaviour is in app/config.py. This document is itself generated by tools/make_docs.py from those constants, and both are part of the hashed source listing.

End of technical validation document for Crypto Investigator v0.4.0, generated 2026-07-09 17:29 UTC.